

지란지교 해커톤 · STEP 2 MVP 제출

OfficeBridge

클라이언트리스 제로트러스트 게이트웨이 프로토타입 — 개발 결과 보고서

작성일	2026-08-27
커밋 수	총 41개 커밋
구성	릴레이 서버 · 로그인 게이트형 커넥터 앱 · 개인 브릿지 앱 (Windows/Mac 지원)

1. 프로젝트 개요

1.1 배경 및 문제 정의

기존 VPN 기반 사내망 접근 방식은 클라이언트 설치·설정이 번거롭고, 한 번 접속하면 사내망 전체가 열리는 "암묵적 신뢰" 구조라는 한계가 있습니다. OfficeBridge는 이를 **클라이언트리스(브라우저만으로 접속) + 제로트러스트(요청마다 재검증)** 구조로 대체하는 것을 목표로 합니다.

1.2 핵심 설계 원칙

- **인바운드 포트를 사내망 쪽으로 열지 않는다** — 커넥터가 릴레이로 아웃바운드 WSS 터널을 먼저 연다.
- **모든 요청을 재검증한다** — 인증 → 정책(부서/개인) → 행위 기반 룰 → 터널 전달 순서로, 캐시된 신뢰를 두지 않는다.
- **로그인 없이는 아무 트래픽도 중계하지 않는다** — 커넥터·브릿지 앱 모두 로그인 게이트형으로 설계해, 자격증명이 없으면 터널/접속 자체가 존재하지 않는다.
- **관리자가 파일을 만들어 배포하지 않는다** — 임직원·관리자 모두 회사코드+계정으로 앱에서 직접 자가등록(self-service)한다.

41

커밋

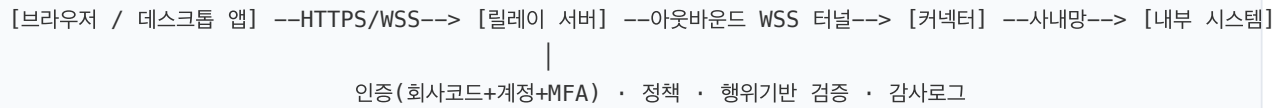
3

주요 구성요소
(릴레이·커넥터·브릿지)

2

지원 플랫폼
(Windows·macOS)

2. 시스템 아키텍처



2.1 릴레이 서버 (relay/)

사내망 밖(또는 경계)에 위치하는 유일한 공개 노출 지점입니다. 사용자 인증, TOTP 기반 2차 인증, 부서/개인별 접근 정책, 행위 기반 지속 검증(업무시간외 차단·요청빈도 제한·세션 IP 고정·로그인 잠금·세션 최대수명), 감사로그, 관리자 콘솔을 담당합니다. Node.js 표준 `http / https / ws` 모듈만으로 프레임워크 없이 구현했습니다.

2.2 커넥터 앱 (connector-app/)

사내망 안의 장비(Windows/Mac)에 설치하는 Electron 데스크톱 앱입니다. **로그인 게이트형**으로 설계해, 관리자가 회사코드+계정(+MFA)으로 로그인해야만 릴레이로의 아웃바운드 WSS 터널이 시작됩니다. 로그인마다 개인화된 토큰이 발급되며, 재로그인 시 이전 토큰은 자동 무효화되고 관리자 콘솔에서 "연결 강제 종료"로 즉시 끊을 수 있습니다. 실제 내부 시스템 주소는 이 앱만 알고 있으며, 릴레이에는 서비스명만 보고됩니다.

2.3 개인 브릿지 앱 (agent-bridge-app/)

임직원용 Electron 데스크톱 앱(Windows/Mac)입니다. 회사코드+계정으로 최초 1회만 인증하면 개인 브릿지 토큰을 로컬에 저장하고, 그 뒤로는 비밀번호 로그인 없이 본인이 접근 가능한 시스템을 클릭 한 번으로 엽니다. 클릭할 때마다 토큰을 세션으로 새로 교환하는 구조라 로컬에 세션을 캐싱하거나 만료를 신경 쓸 필요가 없고, 관리자가 조직도에서 "접근 회수"를 누르면 다음 상태 확인 주기(최대 15초) 내에 자동으로 로그아웃됩니다.

3. 핵심 기능

3.1 P0 (초기 구현)

기능	설명
F-1 터널링	커넥터 아웃바운드 전용 WSS 터널, 요청/응답 JSON 봉투 방식, 하트비트로 연결 유실 감지 및 자동 재연결
F-2 인증	이메일/비밀번호, 세션 쿠키, 로그인 연속 실패 시 계정 잠금
F-3 정책 엔진	부서 정책 U 개인 추가 권한. 위반 시 사내망에 요청 자체가 도달하지 않음
F-4 행위 기반 지속 검증	업무시간외 차단 / 요청빈도 제한 / 세션 IP 고정 / 세션 최대수명
F-5 감사로그	로그인/접속/관리자 조작 전체 기록, 실시간 SSE 스트리밍
F-6 관리자 콘솔	대시보드/조직도/사내시스템현황/정책접근관리/행위기반제어/세션계정통제/로그조회/설치파일

3.2 P0 이후 추가 구현

기능	설명
실제 사내 시스템 연동	mock을 넘어 실제 ERP·GitLab 연동 확인 (HTTPS 백엔드, 리다이렉트 도메인 재작성, 자체서명 인증서 처리, 세션 쿠키 처리)
F-11 개인 브릿지	임직원 자가등록형 데스크톱 앱, 접근 회수 시 자동 로그아웃
로그인 게이트형 커넥터	상시구동 데몬 방식 폐기 → 관리자 로그인 시에만 터널 동작
2차 인증(MFA)	Google Authenticator 호환 TOTP 자체 구현(RFC 6238), 계정별/전체 필수 지정 가능
조직도 관리 고도화	회사→부서→임직원 트리 UI, 아바타·검색·통계 타일, 모달형 추가, 톱니바퀴 메뉴(수정/삭제)
관리자 프로필 셀프서비스	이름·비밀번호 변경을 콘솔에서 직접 처리
회사코드 로그인 게이트	포털 로그인에 회사코드 입력 추가 — 향후 멀티테넌트 확장을 고려한 구조
Windows/Mac 동시 지원	커넥터·브릿지 앱 모두 두 플랫폼 빌드를 자가등록 다운로드로 제공

4. 보안 설계

4.1 관리자 자격증명 탈취 대응 — MFA

로그인 게이트형 커넥터는 "비밀번호 하나로 사내망 터널을 여는" 고위험 지점이 됩니다. 이를 보완하기 위해 RFC 6238(TOTP) 기반 2차 인증을 외부 라이브러리 없이 Node `crypto` 만으로 직접 구현했고, RFC 4226 표준 테스트 벡터로 정확성을 검증했습니다. 관리자는 계정별로 MFA를 필수로 지정하거나 전체 계정에 일괄 필수화할 수 있으며, 등록 비밀키는 본인 화면에만 노출되고 관리자에게는 보이지 않습니다.

4.2 토큰 설계

초기의 고정 공유 토큰(모든 커넥터가 같은 값 사용) 방식을 폐기하고, 로그인마다 개인화된 토큰을 발급하는 구조로 전환했습니다. 재로그인 시 이전 토큰은 자동 무효화되어 "한 계정당 하나의 활성 세션"이 보장되고, 관리자가 즉시 강제 종료할 수 있습니다.

4.3 자체서명 인증서 처리 범위 제한

릴레이 자체 인증서와 사내 시스템(대개 내부 CA 또는 자체서명)에 대해 `rejectUnauthorized: false` 를 적용하되, **해당 연결 하나에만 국한**시켰습니다 — 프로세스 전역 설정(`NODE_TLS_REJECT_UNAUTHORIZED=0`)을 피해, 다른 외부 HTTPS 요청까지 검증이 풀리는 사고를 방지했습니다.

4.4 접근 회수의 즉시성

퇴사·기기 분실 시 관리자가 조직도에서 "접근 회수"를 누르면 해당 토큰이 서버에서 즉시 무효화되고, 브릿지 앱은 다음 폴링에서 401을 받아 로컬 자격증명을 스스로 삭제하고 로그인 화면으로 전환합니다.

비밀번호 입력란은 관리자 콘솔 전 영역에서 `type="password"` 로 마스킹되어 있으며, 관리자 화면에 평문으로 노출되는 지점이 없는지 별도로 점검했습니다.

5. 개발 히스토리

아래는 구현 순서대로 정리한 주요 단계입니다. 커밋 메시지와 전체 이력은 `docs/03_전체_커밋로그.md`에 별도로 정리했습니다.

개발 순서

1. 릴레이 핵심(인증/정책/행위기반검증/터널/감사로그) + 관리자 콘솔/포털 UI + mock 앱 4종 구현
2. 커넥터 핵심(WSS 터널) + 로컬 관리 웹 + 실습 가이드/제출 문서 1차 작성
3. 조직도 관리 + F-11 개인 브릿지 API, 커넥터 메뉴바 앱, 실제 사내 시스템 연동
4. 브릿지 앱 자가등록 전환, 배포 대상 통일, 다운로드 공개화
5. 로그인 게이트형 커넥터로 전면 재설계, 조직도 UI 고도화, MFA 도입, 데모 데이터 전량 삭제 후 실서비스 초기화
6. 정책접근관리·계정통제 톤 통일, 회사코드 로그인 게이트, 조직도 CRUD 완성(수정/삭제/부서관리), 관리자 프로필 셀프서비스, Windows 빌드 추가, 보안 점검(비밀번호 마스킹)

6. 알려진 한계 및 다음 단계

한계	영향	다음 단계
세션·터널 상태가 인메모리	릴레이 재시작 시 웹 세션·커넥터 연결 끊김, 재로그인 필요	영속 스토리지 또는 무중단 재시작(rolling restart) 도입
Windows 빌드 미서명	SmartScreen 경고, 파일 속성상 제품명/아이콘이 기본값	정식 코드사인링 인증서 확보, CI 기반 Windows 빌드 환경 구축
단일 테넌트 구조	회사코드 하나만 지원	회사코드별 데이터 완전 분리(멀티테넌트) 설계
커넥터 서비스 삭제 미전파	커넥터에서 지운 서비스가 릴레이에 "연결 안됨"으로 잔존	삭제 전파 메시지 추가
F-8/F-9/F-10 미착수	추가인증 확장, AI 요약, 커넥터 모니터링 대시보드	STEP 3 로드맵으로 이관